

Restaurant Automation SaaS

Product Requirements Document (PRD)

Version: 2.1

1. Product Overview

Restaurant Automation SaaS is a multi-tenant restaurant operating system that automates the complete dining lifecycle and restaurant operations.

The platform supports:

- QR-based ordering
 - Table sessions
 - Menu management
 - Cart management
 - Order lifecycle
 - Kitchen workflows
 - Staff workflows
 - Billing
 - Payments
 - Cleaning operations
 - Feedback
 - Reservations
 - Loyalty
 - Inventory
 - Analytics
 - Notifications
 - Restaurant administration
 - Platform administration
-

2. Authentication Strategy

Customer Authentication

Required:

- Name
- Mobile Number

- OTP Verification

Optional:

- Email

Rules:

- No password required
- No email verification required
- OTP acts as login mechanism
- OTP acts as account recovery mechanism
- Mobile number is unique

Flow:

Mobile → OTP → Login

Staff Authentication

Applicable Roles:

- Service Staff
- Kitchen Staff
- Cleaning Staff
- Restaurant Admin
- Super Admin

Required:

- Email
- Password

Authentication:

- JWT Access Token
 - Refresh Token
-

Password Recovery

Applicable Roles:

- Service Staff
- Kitchen Staff
- Cleaning Staff

- Restaurant Admin
- Super Admin

Flow:

Forgot Password → Request OTP → OTP Verification → Reset Password → Invalidate Existing Sessions → Login Again

Security Rules:

- OTP expires after 5 minutes
 - Maximum 5 attempts
 - OTP is single use
 - Password reset must be audit logged
 - Existing refresh tokens must be revoked
-

Future MFA

Applicable Roles:

- Restaurant Admin
- Super Admin

Future support:

- Email OTP
 - SMS OTP
 - Authenticator App MFA
-

3. Security Requirements

Mandatory:

- JWT Authentication
- OTP Verification
- Tenant Isolation
- RBAC Enforcement
- Audit Logging
- Socket Authentication
- Rate Limiting
- Ownership Validation
- Payment Signature Verification

All socket connections must be authenticated.

Cross-tenant access must be blocked.

4. Real-Time Events

- order:new
- order:accepted
- order:preparing
- order:ready
- order:picked
- order:served
- notification:new
- session:expired
- table:status-updated

All socket rooms must validate:

- user identity
 - role
 - tenant ownership
-

5. Core Modules

Customer

- Session
- Menu
- Cart
- Orders
- Requests
- Billing
- Payments
- Feedback
- Loyalty

Operations

- Kitchen
- Staff
- Cleaning

Administration

- Tables
- Menu

- Inventory
- Reservations
- Analytics
- Notifications

Platform

- Super Admin
 - Subscriptions
 - Audit Logs
 - Feature Flags
 - Upload Service
-

6. Acceptance Criteria

Platform is accepted only if:

- Dining lifecycle works end-to-end
 - RBAC verified
 - Tenant isolation verified
 - Socket authentication verified
 - Payment verification verified
 - Audit logs operational
 - Notifications operational
 - APIs documented
 - Postman collection passing
 - Security review passing
-

7. Future Roadmap

Phase 2

- OTP Customer Auth
- Password Recovery OTP
- Socket Security
- Tenant Hardening
- Payment Hardening

Phase 3

- Loyalty Engine
- Subscriptions
- Upload Service

Phase 4

- AI Recommendations
- Advanced Analytics
- Multi Branch Operations